

Relazione Tecnica di Analisi Forense di Rete

Oggetto: Identificazione della Metodologia di Scansione ed Elaborazione delle Contromisure su Traffico PCAPNG (Cattura_U3_W1_L5.pcapng)

Dettagli dell'Analisi

Parametro	Valore / Descrizione
File Analizzato	Cattura_U3_W1_L5.pcapng
Unità / Lezione	Unità 3 - Settimana 9 - Lezione 5
Target Monitorato	Metasploitable (Samba 3.0.20-Debian)
Ambiente Originario	Kali Linux (Kernel 5.15) / Dumpcap 3.6.5

1. Sintesi Esecutiva

A seguito dell'ispezione approfondita del traffico di rete contenuto nel file Cattura_U3_W1_L5.pcapng, è stato identificato con certezza l'esatto comando di ricognizione lanciato dall'host attaccante:

```
nmap -sT -p 1-1024 <IP_Target>
```

L'analisi ha confermato che l'attività non costituisce una semplice scansione stealth (SYN scan), bensì una **TCP Connect Scan completa (-sT)** rivolta verso il range standard delle porte privilegiate (1-1024). Di seguito viene dettagliata la catena di deduzione tecnica e le relative strategie di difesa e mitigazione.

2. Metodologia di Deduzione Forense

2.1. Il Pacchetto "Zero" (Time 0.000000) e il Traffico di Sfondo

L'analisi del file evidenzia al primo timestamp (0.000000) un frame appartenente al protocollo **BROWSER** (SMB Host Announcement):

```
SMB% \MAILSLOT\BROWSE METASPLOITABLE metasploitable server (Samba 3.0.20-Debian)
```

Questo pacchetto non fa parte dell'attacco attivo. Si tratta di un broadcast spontaneo generato dal servizio Samba del server Metasploitable per annunciare la propria presenza sulla rete locale. Risulta catalogato con timestamp 0.000000 unicamente perché è stato intercettato dallo sniffer di rete (dumpcap) nell'istante esatto dell'avvio della cattura.

2.2. Prova Inconfutabile del 3-Way Handshake Completo (-sT vs -sS)

La distinzione tra un TCP Connect Scan e uno Stealth SYN Scan si basa sulla gestione dell'handshake TCP per le porte aperte sul bersaglio:

- **TCP SYN Scan (-sS / Stealth):** L'host attaccante invia un pacchetto SYN. La vittima risponde con SYN-ACK. L'attaccante invia immediatamente un pacchetto RST (Reset) per interrompere la connessione prima del suo completamento. La connessione non viene mai stabilita a livello di sistema operativo e non viene registrata dai log applicativi del server.
- **TCP Connect Scan (-sT / Non-Stealth):** L'host attaccante invia un pacchetto SYN. La vittima risponde con SYN-ACK. L'attaccante risponde con un pacchetto ACK, completando l'intero **3-Way Handshake** prima di terminare la sessione via FIN/RST.

Nel file di cattura esaminato, la presenza sistematica della sequenza **SYN → SYN-ACK → ACK** dimostra in modo inequivocabile che il sistema operativo dell'attaccante ha aperto una connessione socket completa tramite la chiamata di sistema nativa connect(), caratteristica peculiare del parametro -sT di Nmap.

2.3. Definizione del Range di Porte (-p 1-1024)

L'ispezione dei pacchetti TCP successivi al pacchetto zero evidenzia interrogazioni sequenziali e sistematiche sulle porte di destinazione comprese esattamente tra la porta **1** e la porta **1024** (Well-Known Ports), evidenziando l'uso dell'argomento esplicito -p 1-1024.

3. Tabella Comparativa delle Tecniche di Scansione

Caratteristica	TCP Connect Scan (-sT)	TCP SYN Scan (-sS)
Sequenza Pacchetti	SYN → SYN-ACK → ACK → RST	SYN → SYN-ACK → RST
Completamento Handshake	Sì (Completo)	No (Parziale / Abortito)
Invisibilità (Stealth)	Bassa (Tracciabile nei log di sistema)	Alta (Evita la registrazione delle sessioni)

Caratteristica	TCP Connect Scan (-sT)	TCP SYN Scan (-sS)
Privilegi Richiesti	Utente Standard (chiamata connect())	Privilegi Root / Administrator (Raw Sockets)
Riscontro nella Cattura	Identificato nel file Cattura_U3_W1_L5	Escluso dall'analisi effettuata

4. Soluzioni e Mitigazioni contro le Scansioni di Rete

Per prevenire, rilevare e neutralizzare le attività di port scanning e la successiva enumerazione dei servizi, si raccomanda l'adozione di un'architettura di difesa a più livelli (Defense-in-Depth):

4.1. Configurazione del Firewall e Rate Limiting

Utilizzare il firewall di sistema (es. iptables o nftables su Linux) per limitare la frequenza delle nuove connessioni TCP e bloccare gli host che effettuano tentativi di connessione ad alta frequenza:

```
iptables -A INPUT -p tcp --syn -m state --state NEW -m recent --set
iptables -A INPUT -p tcp --syn -m state --state NEW -m recent --update --seconds 60
--hitcount 20 -j DROP
```

4.2. Implementazione di IDS/IPS Dinamici (Snort / Suricata / Fail2ban)

- **Snort / Suricata:** Configurare regole di Intrusion Detection per sollevare alert in presenza di scansioni Nmap. Esempio di regola Snort per TCP Connect Scan:
alert tcp any any -> \$HOME_NET any (msg:"NMAP TCP Connect Scan Detected";
flags:A; ack:1; threshold: type threshold, track by_src, count 30, seconds 10;
sid:1000001;)
- **Fail2ban / PortSentry:** Impiegare strumenti di prevenzione attiva che analizzano i log di sistema e inseriscono automaticamente gli IP rilevati in blacklist dinamiche del firewall.

4.3. Hardening dei Servizi e Shielding delle Informazioni (Samba / SMB)

Nel caso specifico del servizio Samba evidenziato nella cattura, è necessario impedire che il server risponda esponendo la versione del software o inviando annunci di broadcast BROWSER. All'interno del file /etc/samba/smb.conf, impostare:

```
local master = no
os level = 0
```

server string = File Server

4.4. Port Knocking e Deception (Honeypot / Tarpit)

- **Port Knocking:** Mantenere le porte di gestione sensibili (es. SSH) totalmente chiuse fino alla ricezione di una sequenza predefinita e segreta di pacchetti su porte specifiche.
- **Tarpit:** Impiegare moduli come iptables TARPIT per rallentare intenzionalmente lo scanner dell'attaccante, esaurendo le sue risorse e rendendo la scansione inefficace.